

Cyber Security Internship Week 1 Tasks

Task1: Understanding Cybersecurity Fundamentals:

Q1: Confidentiality, Integrity, and Availability (CIA Triad)?

Ans: **Confidentiality:** Confidentiality in security means keeping information private and making sure only the right people can access it. It's about protecting data from being seen or used by anyone who isn't allowed to. Some ways to keep information confidential include:

- Access Control: Only letting specific people access certain information.
- Encryption: Scrambling data so it's unreadable to anyone without the proper key.
- Authentication: Checking who someone is before allowing access.
- Least Privilege: Giving people only the access they need to do their job.

The goal of confidentiality is to prevent unauthorized access, protect sensitive information, and keep data secure.

Integrity: It refers to the assurance that data remains accurate, complete, and unaltered during storage, transmission, and processing

Availability: availability means making sure that systems and data are accessible to authorized users whenever they need them. It involves backup plans, protection against disruptions, and constant monitoring to prevent downtime and keep services running smoothly.

Q2: Types of cyber-attacks (e.g., phishing, malware, denial-of-service)?

Ans: Here are some common types of cyber-attacks:

1. **Phishing:** Tricks people into sharing personal information, like passwords or credit card numbers, through fake emails or websites that look legitimate.
2. **Malware:** Malicious software (like viruses, trojans, and ransomware) that can damage systems, steal data, or hold files hostage.
3. **Denial of Service (DoS) and Distributed Denial of Service (DDoS):** Overloads a network or website with traffic to make it inaccessible to users.
4. **Man-in-the-Middle (MitM) Attack:** An attacker intercepts communications between two parties to eavesdrop or alter the information.

5. **SQL Injection:** Exploits vulnerabilities in a website's database query to gain access to sensitive data or take control of the system.
6. **Password Attacks:** Attempts to guess or steal passwords using methods like brute force, credential stuffing, or social engineering.
7. **Zero-Day Exploit:** Targets newly discovered vulnerabilities that developers haven't yet fixed, often causing significant damage before detection.
8. **Cross-Site Scripting (XSS):** Injects malicious scripts into trusted websites, enabling attackers to steal data or hijack user sessions.

Each type targets systems differently, with various goals such as stealing data, disrupting services, or gaining unauthorized access.

Q3: Importance of network security, data protection, and user authentication?

Ans: Network security, data protection, and user authentication are crucial to safeguarding sensitive information, ensuring privacy, and maintaining trust. Here's why each is important:

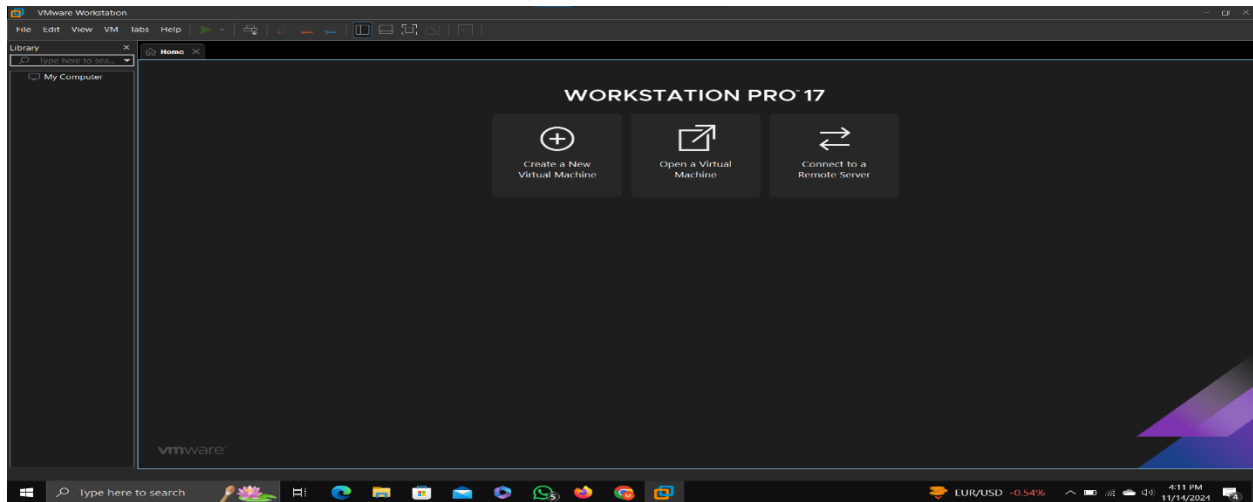
- **Network Security:** Protects the infrastructure (like computers, servers, and networks) from unauthorized access, malware, and attacks. This keeps data safe, prevents downtime, and stops attackers from spreading harmful activities across networks.
- **Data Protection:** Ensures that sensitive data (such as personal and financial information) is kept private, accurate, and safe from breaches or loss. This is essential for privacy, compliance, and trust, especially with sensitive customer or organizational data.
- **User Authentication:** Verifies the identity of users accessing systems, preventing unauthorized people from gaining access. Strong authentication (like multi-factor authentication) helps prevent identity theft, data breaches, and unauthorized activities.

Together, these protect organizations and individuals from threats, reduce risk, and help maintain secure and reliable access to information.

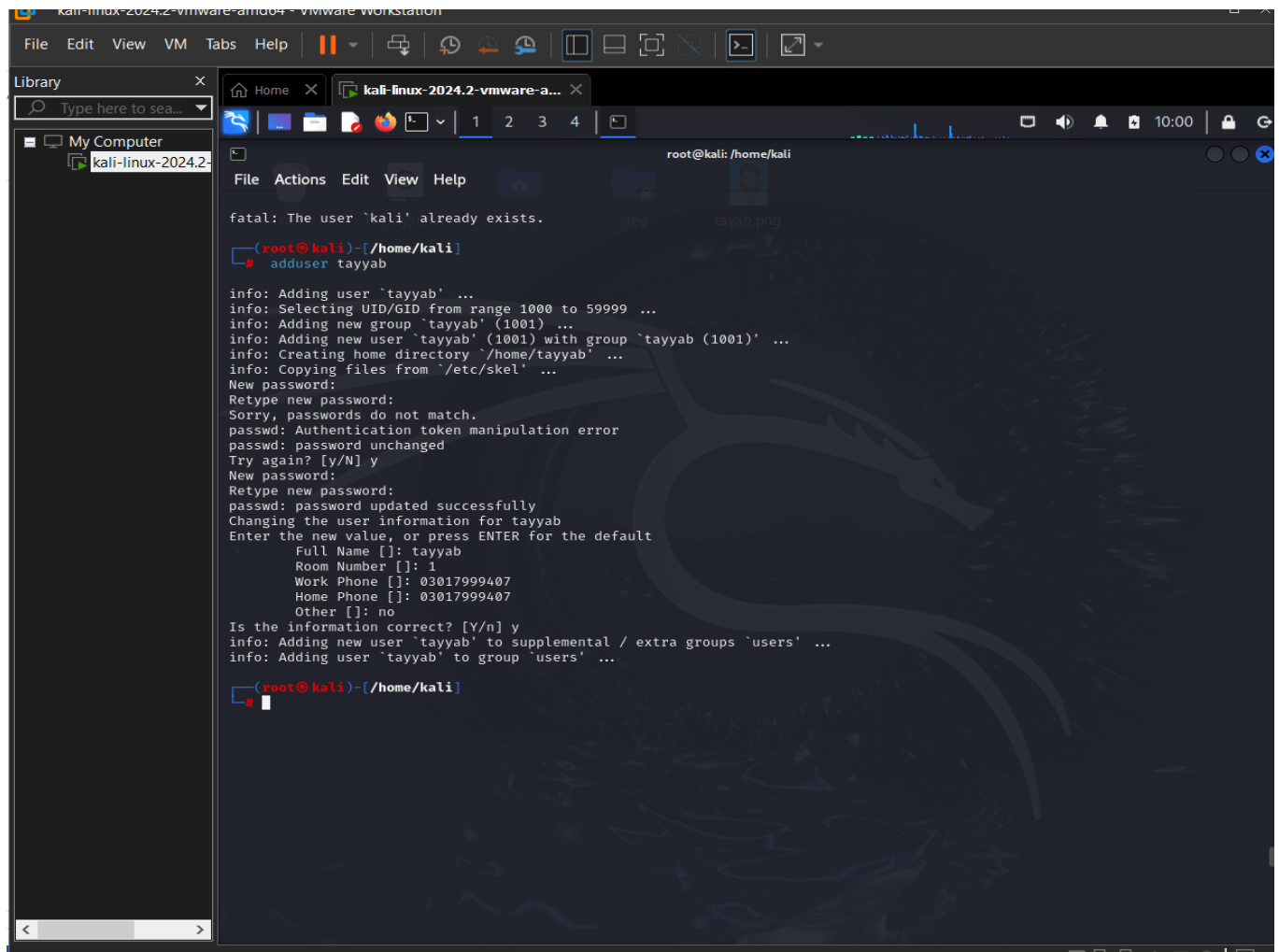
Task 2: Setting Up a Secure Virtual Environment

Screenshots

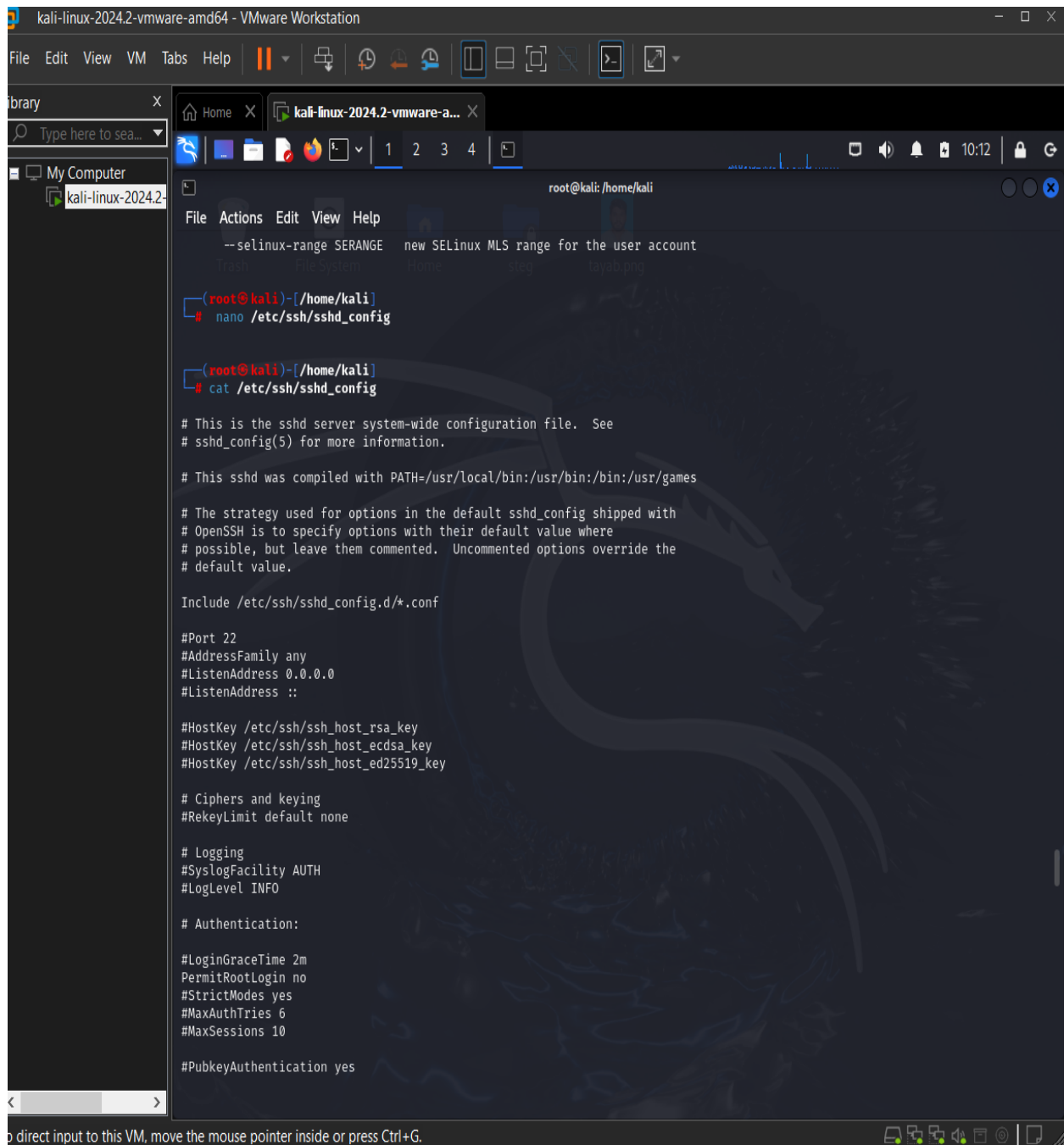
VMware



Create non-root User



Open the SSH configuration file:



The screenshot shows a VMware Workstation window titled "kali-linux-2024.2-vmware-amd64 - VMware Workstation". Inside the VM, a terminal window is open with the prompt "root@kali: /home/kali". The terminal shows the following commands and output:

```
File Actions Edit View Help
--selinux-range SERANGE new SELinux MLS range for the user account
(root@kali)-[/home/kali]
# nano /etc/ssh/sshd_config

(root@kali)-[/home/kali]
# cat /etc/ssh/sshd_config

# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/bin:/usr/games

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

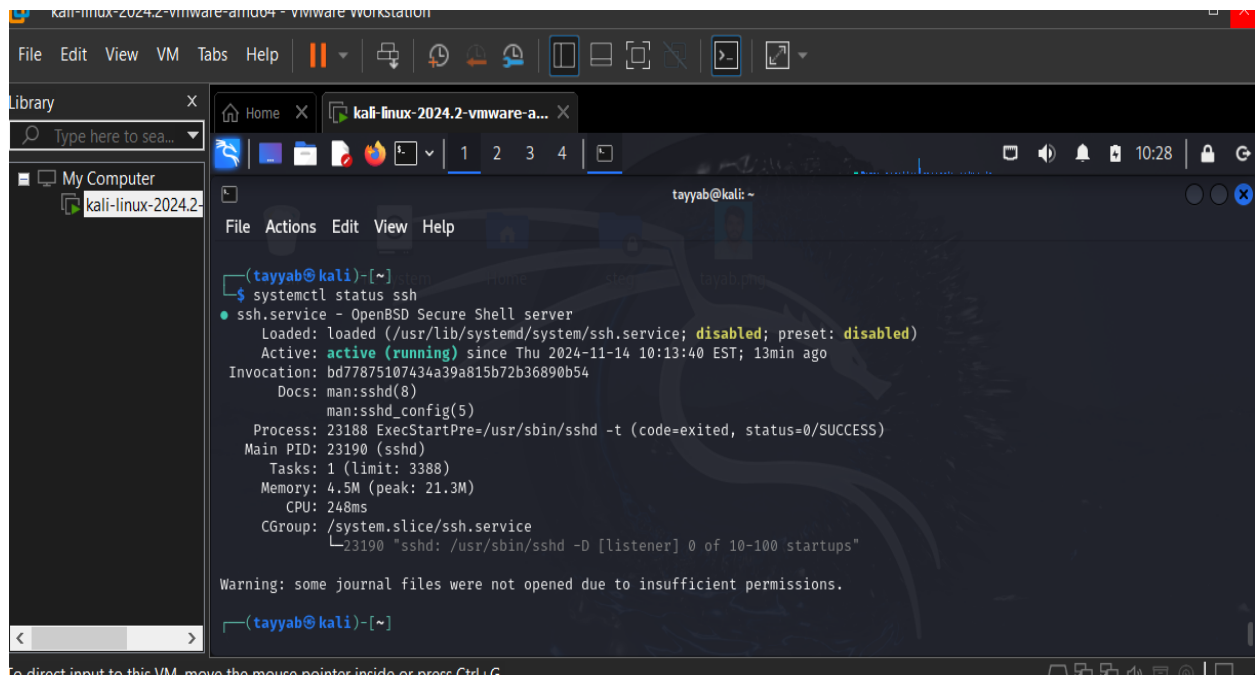
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes
```

At the bottom of the VMware window, a status bar reads: "To direct input to this VM, move the mouse pointer inside or press Ctrl+G."



Ssh Status check

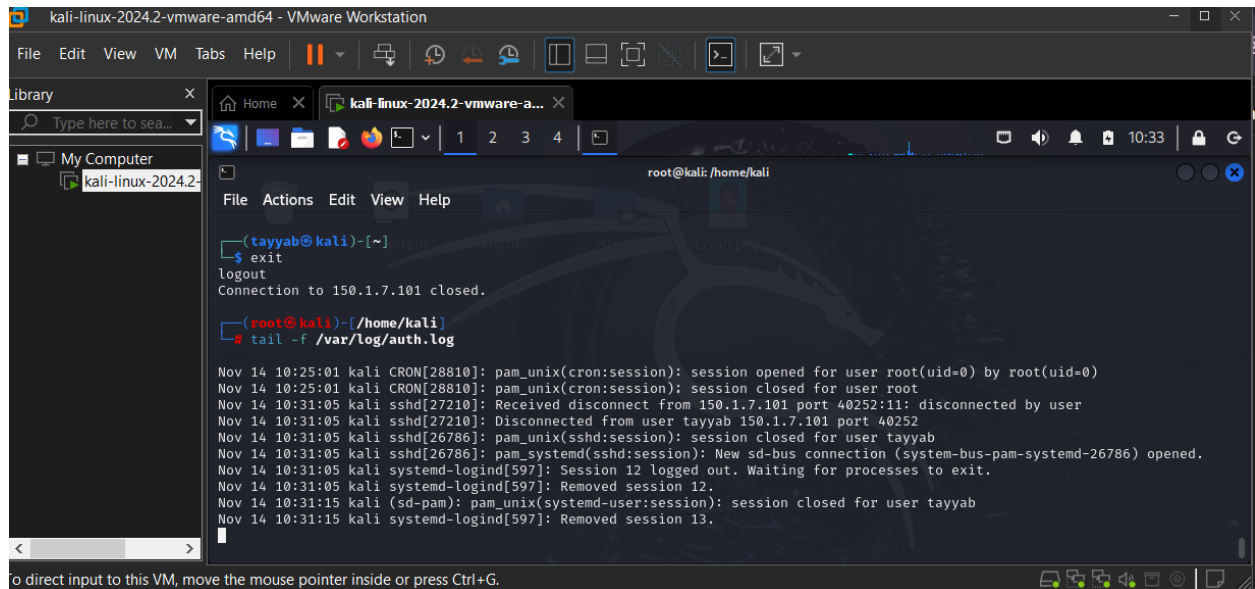


The screenshot shows a terminal window titled "kali-linux-2024.2-vmware-amd64 - VMware Workstation". The user is logged in as "tayyab@kali". The terminal output of the command `systemctl status ssh` is as follows:

```
(tayyab@kali)-[~]
$ systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Thu 2024-11-14 10:13:40 EST; 13min ago
   Invocation: bd77875107434a39a815b72b36890b54
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 23188 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 23190 (sshd)
     Tasks: 1 (limit: 3388)
    Memory: 4.5M (peak: 21.3M)
       CPU: 248ms
    CGroup: /system.slice/ssh.service
           └─23190 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Warning: some journal files were not opened due to insufficient permissions.

(tayyab@kali)-[~]
```

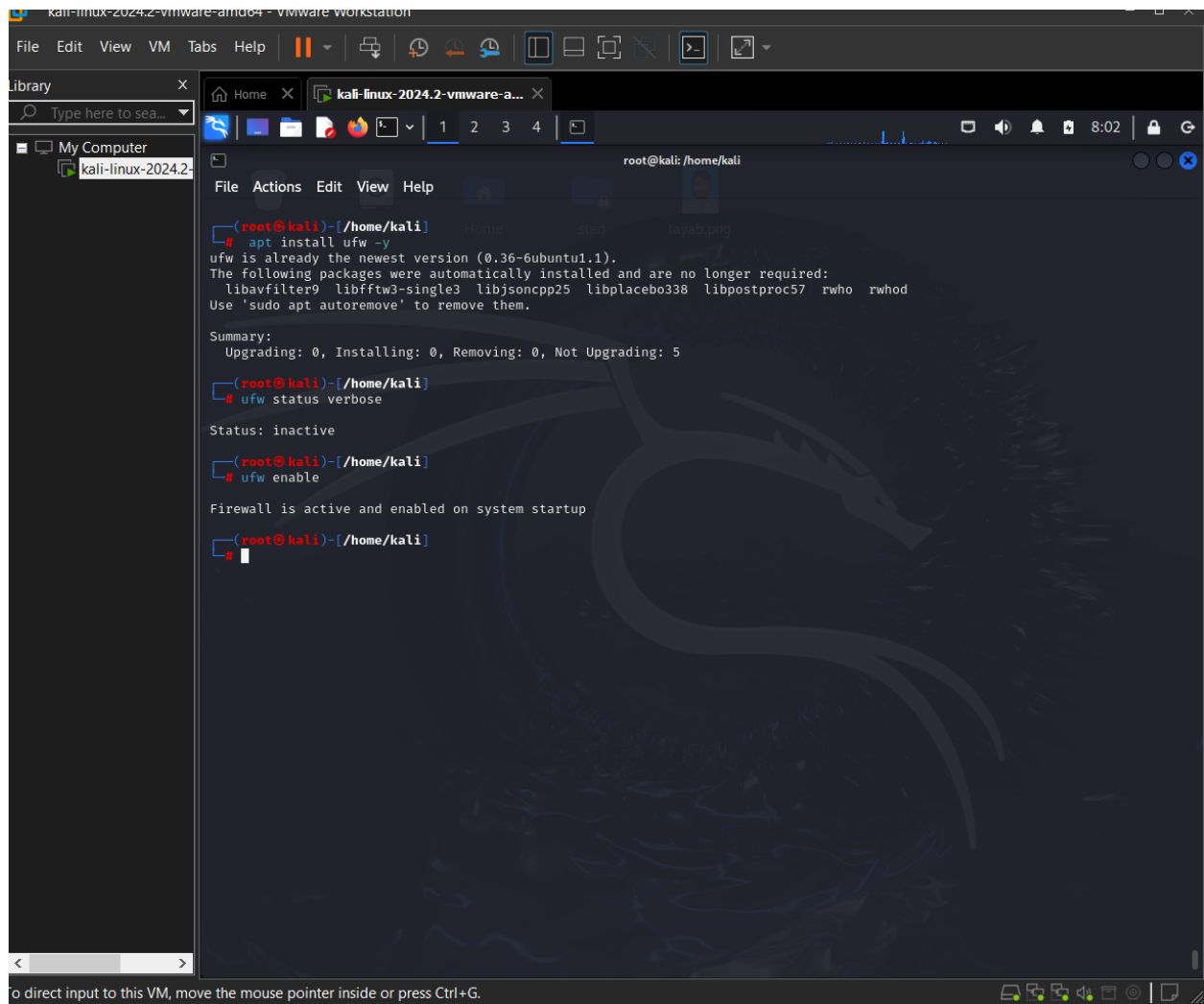


The screenshot shows the same terminal window after the user has exited the SSH session. The output of the `exit` command is shown, followed by the `tail -f /var/log/auth.log` command output:

```
(tayyab@kali)-[~]
$ exit
logout
Connection to 150.1.7.101 closed.

(root@kali)-[/home/kali]
# tail -f /var/log/auth.log
Nov 14 10:25:01 kali CRON[28810]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
Nov 14 10:25:01 kali CRON[28810]: pam_unix(cron:session): session closed for user root
Nov 14 10:31:05 kali sshd[27210]: Received disconnect from 150.1.7.101 port 40252:11: disconnected by user
Nov 14 10:31:05 kali sshd[27210]: Disconnected from user tayyab 150.1.7.101 port 40252
Nov 14 10:31:05 kali sshd[26786]: pam_unix(sshd:session): session closed for user tayyab
Nov 14 10:31:05 kali sshd[26786]: pam_systemd(sshd:session): New sd-bus connection (system-bus-pam-systemd-26786) opened.
Nov 14 10:31:05 kali systemd-logind[597]: Session 12 logged out. Waiting for processes to exit.
Nov 14 10:31:05 kali (sd-pam): pam_unix(systemd-user:session): session closed for user tayyab
Nov 14 10:31:15 kali systemd-logind[597]: Removed session 12.
Nov 14 10:31:15 kali systemd-logind[597]: Removed session 13.
```

Installing UFW



The screenshot shows a Kali Linux terminal window running inside a VMware Workstation. The terminal is titled 'root@kali: /home/kali'. The user has executed the command `apt install ufw -y`, which has installed UFW. The terminal output shows that UFW is already the newest version (0.36-6ubuntu1.1) and lists several packages that were automatically installed and are no longer required. The user then executes `ufw status verbose`, which shows that the firewall is inactive. Finally, the user executes `ufw enable`, which activates the firewall and enables it on system startup.

```
(root@kali)-[/home/kali]
# apt install ufw -y
ufw is already the newest version (0.36-6ubuntu1.1).
The following packages were automatically installed and are no longer required:
  libavfilter9 libfftw3-single3 libjsoncpp25 libplacebo338 libpostproc57 rwho rwhod
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 5

(root@kali)-[/home/kali]
# ufw status verbose

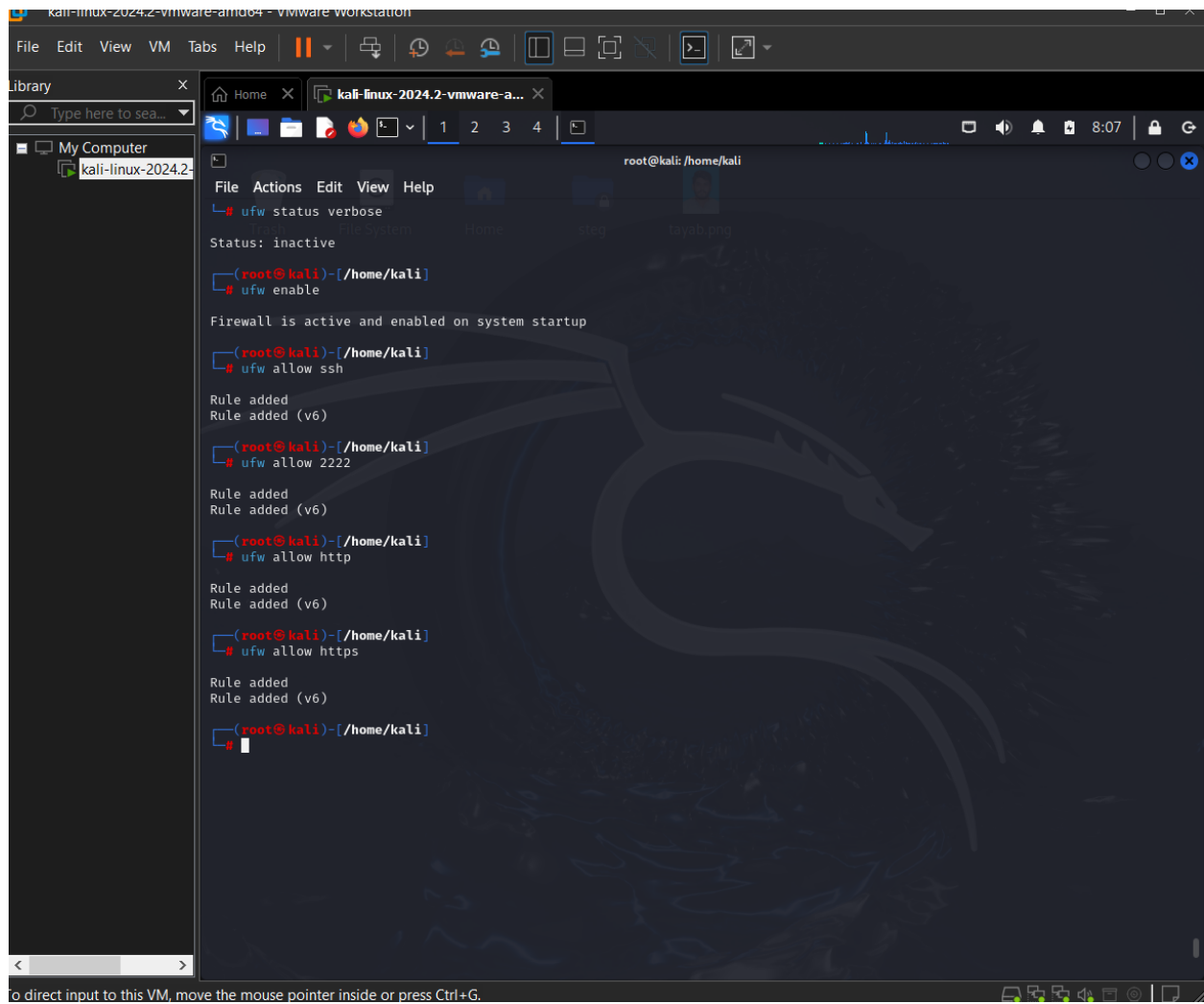
Status: inactive

(root@kali)-[/home/kali]
# ufw enable

Firewall is active and enabled on system startup

(root@kali)-[/home/kali]
#
```

Allow Services



The screenshot shows a Kali Linux terminal window running inside a VMware Workstation. The terminal is at the root user's home directory (/home/kali). The user has executed the following commands:

```
root@kali: /home/kali
# ufw status verbose
Status: inactive

(root@kali)-[/home/kali]
# ufw enable

Firewall is active and enabled on system startup

(root@kali)-[/home/kali]
# ufw allow ssh
Rule added
Rule added (v6)

(root@kali)-[/home/kali]
# ufw allow 2222
Rule added
Rule added (v6)

(root@kali)-[/home/kali]
# ufw allow http
Rule added
Rule added (v6)

(root@kali)-[/home/kali]
# ufw allow https
Rule added
Rule added (v6)

(root@kali)-[/home/kali]
#
```

The terminal output shows that the UFW firewall is now active and has rules added for SSH, port 2222, HTTP, and HTTPS. The background of the terminal window features a large, stylized dragon logo.

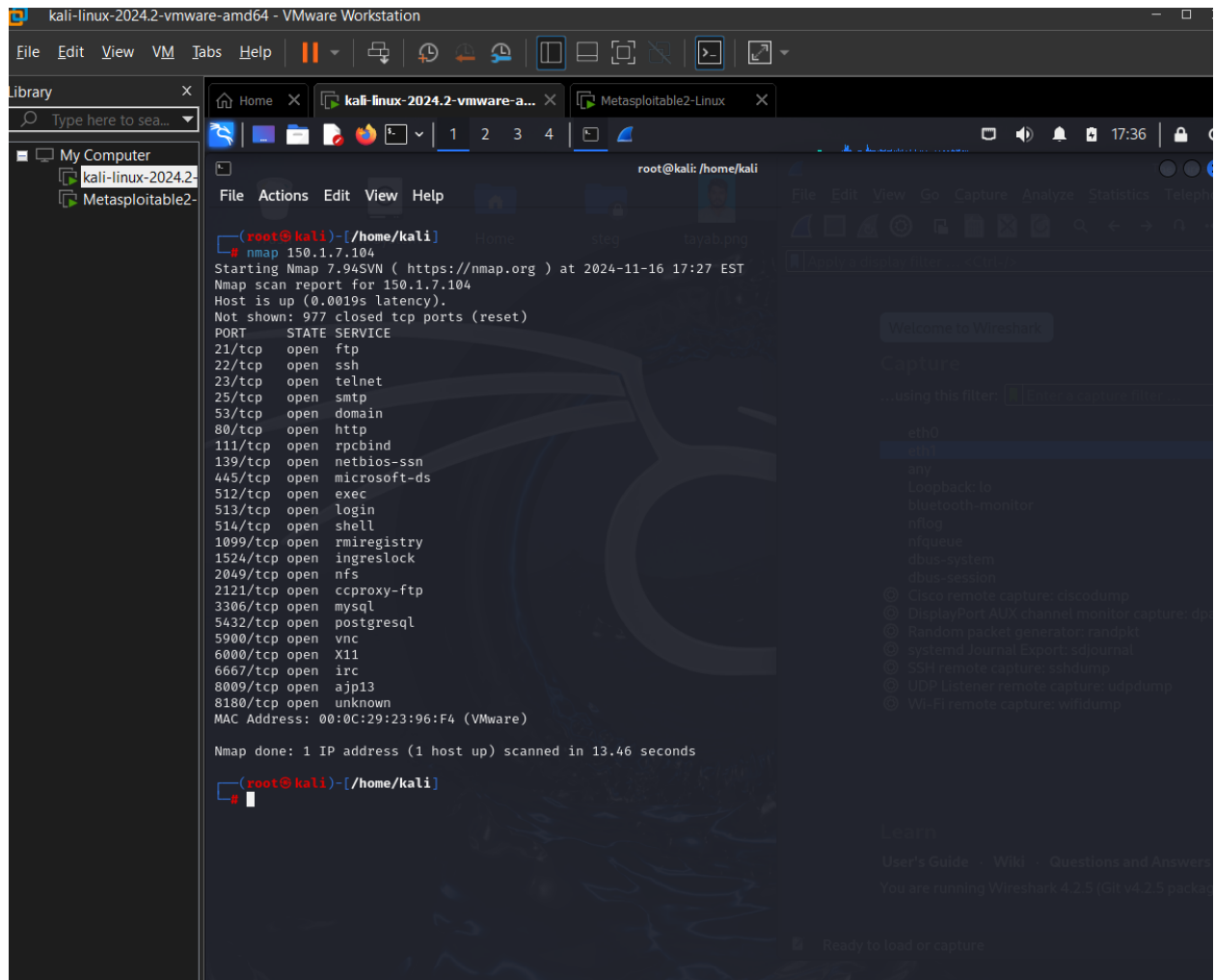
Task 3: Network Security Basics: Packet Analysis

Environment

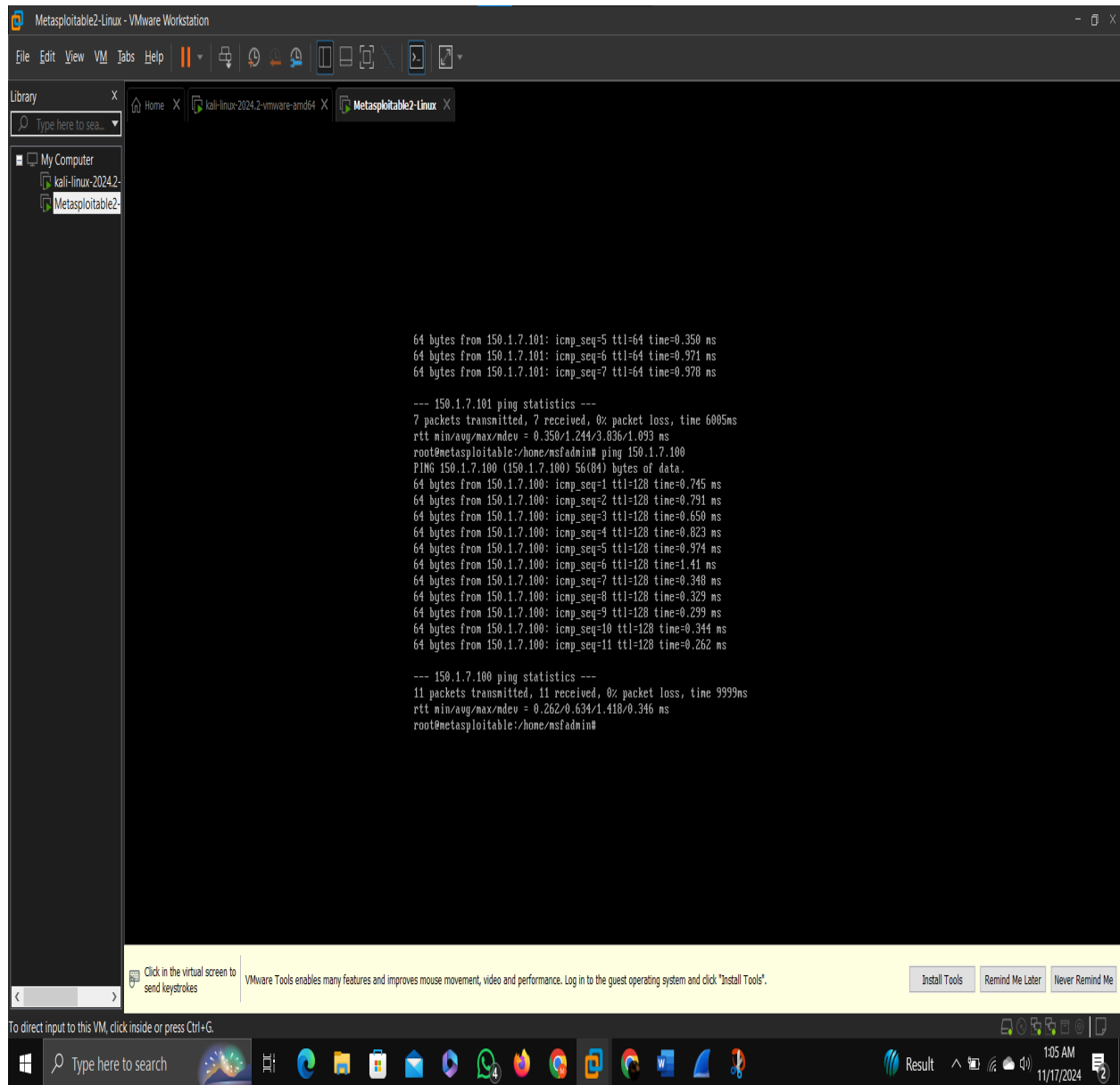
1. **Attacker System:** Kali Linux (ip:150.1.7.101)
2. **Target System:** Metasploitable (ip:150.1.7.104)
3. **Tools Used:**
 - o **Nmap:** Network scanning tool for port discovery and service enumeration.
 - o **Wireshark:** Packet capture and network protocol analysis tool.

Screenshots

Nmap Scan



Metasploitable



Captured Packets:

- SYN packets exchanged during the Nmap scan.
- TCP handshakes for open ports.
- Service banners and responses providing additional details

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	VMware_37:91:d	Broadcast	ARP	60	Who has 150.1.7.104? Tell 150.1.7.101
2	0.000280	VMware_23:96:f4	VMware_37:91:d	ARP	42	150.1.7.104 is at 00:0c:29:23:96:f4
3	14.654363	150.1.7.101	150.1.7.104	TCP	60	62098 → 25 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4	14.654976	150.1.7.104	150.1.7.101	TCP	58	25 → 62098 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
5	14.654982	150.1.7.101	150.1.7.104	TCP	60	62098 → 135 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
6	14.655138	150.1.7.104	150.1.7.101	TCP	54	135 → 62098 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
7	14.655320	150.1.7.101	150.1.7.104	TCP	60	62098 → 25 [RST] Seq=1 Win=0 Len=0
8	14.655591	150.1.7.101	150.1.7.104	TCP	60	62098 → 199 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
9	14.655784	150.1.7.101	150.1.7.104	TCP	60	62098 → 554 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
10	14.655831	150.1.7.104	150.1.7.101	TCP	54	199 → 62098 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
11	14.655935	150.1.7.104	150.1.7.101	TCP	54	554 → 62098 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
12	14.655958	150.1.7.101	150.1.7.104	TCP	60	62098 → 256 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

▶ Frame 3: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface \Device\NPF... id 0

▶ Ethernet II, Src: VMware_37:91:d (00:0c:29:23:96:f4), Dst: VMware_23:96:f4 (00:0c:29:23:96:f4)

▶ Internet Protocol Version 4, Src: 150.1.7.101, Dst: 150.1.7.104

▶ Transmission Control Protocol, Src Port: 62098, Dst Port: 25, Seq: 0, Len: 0

Applying to: VMware Network Adapter VMnet1

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
460	14.672474	150.1.7.101	150.1.7.104	TCP	60	62098 → 6156 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
461	14.672508	150.1.7.101	150.1.7.104	TCP	60	62098 → 1074 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
462	14.672534	150.1.7.101	150.1.7.104	TCP	60	62098 → 1054 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
463	14.672575	150.1.7.101	150.1.7.104	TCP	60	62098 → 2170 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
464	14.672600	150.1.7.101	150.1.7.104	TCP	60	62098 → 49400 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
465	14.672626	150.1.7.101	150.1.7.104	TCP	60	62098 → 1067 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
466	14.672652	150.1.7.101	150.1.7.104	TCP	60	62098 → 5060 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
467	14.672689	150.1.7.101	150.1.7.104	TCP	60	62098 → 12345 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

▶ Frame 463: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface \Device\NPF... id 0

▶ Ethernet II, Src: VMware_37:91:d (00:0c:29:23:96:f4), Dst: VMware_23:96:f4 (00:0c:29:23:96:f4)

▶ Internet Protocol Version 4, Src: 150.1.7.101, Dst: 150.1.7.104

▶ Transmission Control Protocol, Src Port: 62098, Dst Port: 2170, Seq: 0, Len: 0

Apply a display filter ... <Ctrl>/>

No.	Time	Source	Destination	Protocol	Length	Info
15424	15.203615	150.1.7.104	150.1.7.101	TCP	54	13189 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15425	15.203616	150.1.7.104	150.1.7.101	TCP	54	10203 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15426	15.203618	150.1.7.104	150.1.7.101	TCP	54	5652 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15427	15.203620	150.1.7.104	150.1.7.101	TCP	54	35418 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15428	15.203622	150.1.7.104	150.1.7.101	TCP	54	1157 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15429	15.203624	150.1.7.104	150.1.7.101	TCP	54	58014 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15430	15.203626	150.1.7.104	150.1.7.101	TCP	54	48042 → 49634 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
15431	15.203632	150.1.7.101	150.1.7.104	TCP	60	49634 → 49399 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

Frame 15431: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface \Device\NPF_{F0B60420-1942-4930-BF5E-980CE2424687}, id 0
Ethernet II, Src: VMware_37:91:1d (00:0c:29:37:91:1d), Dst: VMware_23:96:f4 (00:0c:29:23:96:f4)
Internet Protocol Version 4, Src: 150.1.7.101, Dst: 150.1.7.104
Transmission Control Protocol, Src Port: 49634, Dst Port: 49399, Seq: 0, Len: 0
Source Port: 49634
Destination Port: 49399
[Stream index: 7714]
[Stream Packet Number: 1]
[Conversation completeness: Incomplete (37)]
[TCP Segment Len: 0]
Sequence Number: 0 (relative sequence number)
Sequence Number (raw): 3221328004
[Next Sequence Number: 1 (relative sequence number)]
Acknowledgment Number: 0
Acknowledgment number (raw): 0
0110 = Header Length: 24 bytes (6)
Flags: 0x02 (SYN)
Window: 1024
[Calculated window size: 1024]
Checksum: 0xa536 [unverified]
[Checksum Status: Unverified]
Urgent Pointer: 0
Options: (4 bytes), Maximum segment size
[Timestamps]

0000 00 0c 29 23 96 f4 00 0c 29 37 91 1d 00 00 45 00 .).....)
0010 00 2c cf 83 00 00 2e 06 82 79 96 01 07 65 96 01y
0020 07 68 c1 e2 c0 f7 c0 01 71 44 00 00 00 60 02 h.....q
0030 04 00 a5 36 00 00 02 04 05 b4 00 00S....

Capturing from VMware Network Adapter VMnet1

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl>/>

No.	Time	Source	Destination	Protocol	Length	Info
895	14.636720	150.1.7.104	150.1.7.101	TCP	54	4129 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
896	14.636723	150.1.7.104	150.1.7.101	TCP	54	9111 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
897	14.636725	150.1.7.104	150.1.7.101	TCP	54	9009 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
898	14.636727	150.1.7.104	150.1.7.101	TCP	54	3871 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
899	14.636730	150.1.7.104	150.1.7.101	TCP	54	15002 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
900	14.636732	150.1.7.104	150.1.7.101	TCP	54	3878 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
901	14.636735	150.1.7.101	150.1.7.104	TCP	60	49109 → 524 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
902	14.636736	150.1.7.104	150.1.7.101	TCP	54	15660 → 49109 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Frame 899: 54 bytes on wire (432 bits), 54 bytes captured (432 bits) on interface \Device\NPF_{F0B60420-1942-4930-BF5E-980CE2424687}, id 0
Ethernet II, Src: VMware_23:96:f4 (00:0c:29:23:96:f4), Dst: VMware_37:91:1d (00:0c:29:37:91:1d)
Internet Protocol Version 4, Src: 150.1.7.104, Dst: 150.1.7.101
Transmission Control Protocol, Src Port: 15002, Dst Port: 49109, Seq: 1, Ack: 1, Len: 0
Source Port: 15002
Destination Port: 49109
[Stream index: 436]
[Stream Packet Number: 2]
[Conversation completeness: Incomplete (37)]
[TCP Segment Len: 0]
Sequence Number: 1 (relative sequence number)
Sequence Number (raw): 0
[Next Sequence Number: 1 (relative sequence number)]
Acknowledgment Number: 1 (relative ack number)
Acknowledgment number (raw): 2127079619
0101 = Header Length: 20 bytes (5)
Flags: 0x014 (RST, ACK)
Window: 0
[Calculated window size: 0]
[Window size scaling factor: -2 (no window scaling used)]
Checksum: 0x5305 [unverified]
[Checksum Status: Unverified]
Urgent Pointer: 0
[Timestamps]
[SEQ/ACK analysis]

0000 00 0c 29 37 91 1d 00 0c 29 23 96 f4 00 00 45 00 .).....)
0010 00 28 00 00 40 00 40 06 00 01 96 01 07 68 96 01
0020 07 65 3a 9a bf d5 00 00 00 00 7e c8 a8 c3 50 14
0030 00 00 53 05 00 00S....

Transmission Control Protocol (tcp), 20 bytes

Packets: 2034 Profile: Default

12:21 AM 11/17/2024

Task 4: Password Security and Hashing

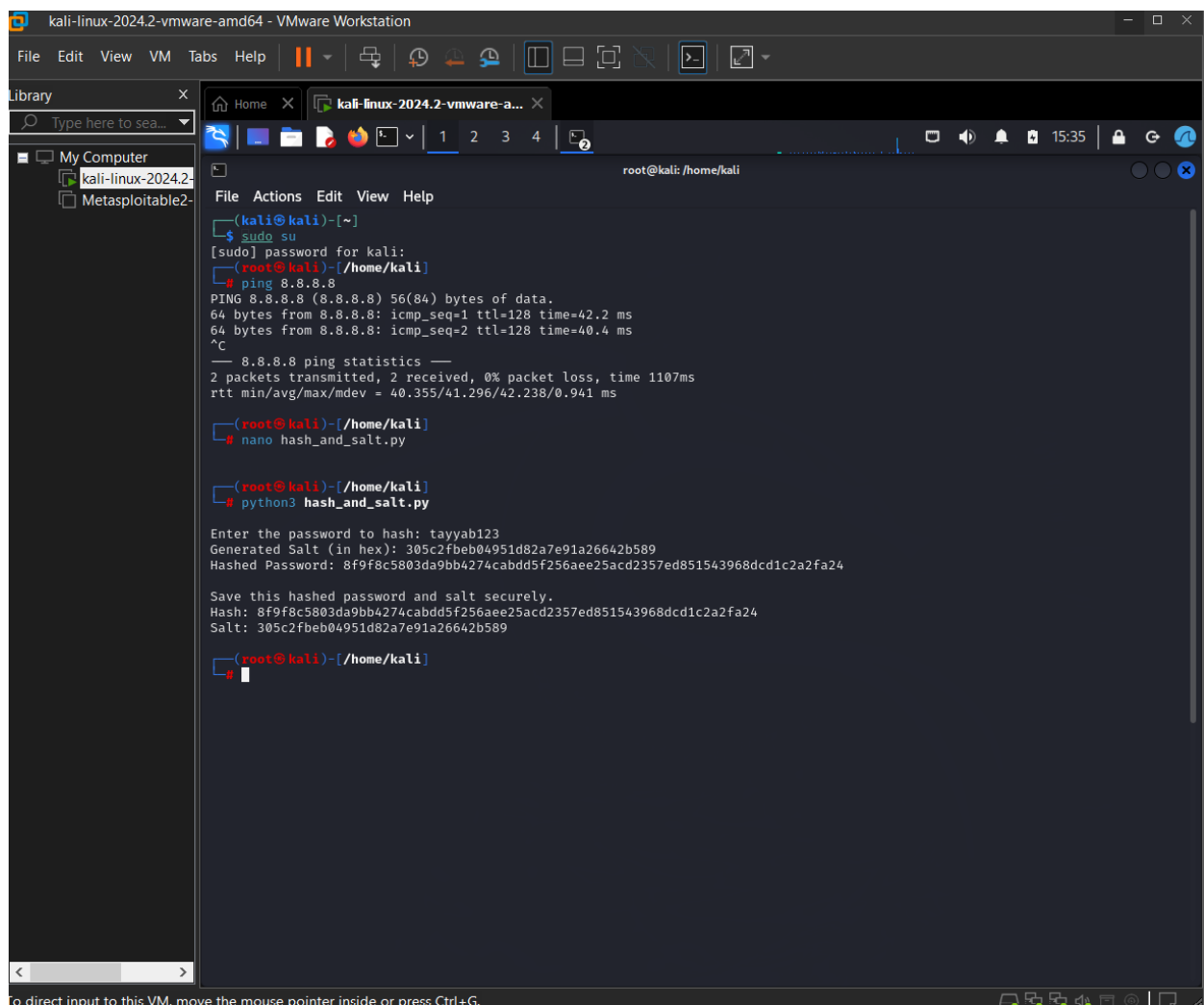
Environment

1. Operating System: Kali Linux
2. Programming Language/Tool: Python and Hashcat
3. Tools/Modules Used:

Python: hashlib module for SHA-256 hashing.

Hashcat: A password recovery tool to demonstrate how salts improve password security.

Screenshots



```
kali-linux-2024.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to sea...
My Computer
kali-linux-2024.2-
Metasploitable2-

root@kali: /home/kali
File Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=128 time=42.2 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=128 time=40.4 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1107ms
rtt min/avg/max/mdev = 40.355/41.296/42.238/0.941 ms
(root@kali)-[/home/kali]
# nano hash_and_salt.py
(root@kali)-[/home/kali]
# python3 hash_and_salt.py

Enter the password to hash: tayyab123
Generated Salt (in hex): 305c2fbeb04951d82a7e91a26642b589
Hashed Password: 8f9f8c5803da9bb4274cabdd5f256aee25acd2357ed851543968dcd1c2a2fa24

Save this hashed password and salt securely.
Hash: 8f9f8c5803da9bb4274cabdd5f256aee25acd2357ed851543968dcd1c2a2fa24
Salt: 305c2fbeb04951d82a7e91a26642b589
(root@kali)-[/home/kali]
#
```

kali-linux-2024.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

kali-linux-2024.2

Metasploitable2

Home

kali-linux-2024.2-vmware-a...

1 2 3 4

root@kali:/home/kali

File Actions Edit View Help

2 packets transmitted, 2 received, 0% packet loss, time 1107ms
rtt min/avg/max/mdev = 40.355/41.296/42.238/0.941 ms

```
(root@kali)-[/home/kali]
# nano hash_and_salt.py

(root@kali)-[/home/kali]
# python3 hash_and_salt.py

Enter the password to hash: tayyab123
Generated Salt (in hex): 305c2fbeb04951d82a7e91a26642b589
Hashed Password: 8f9f8c5803da9bb4274cabdd5f256aee25acd2357ed851543968dcd1c2a2fa24

Save this hashed password and salt securely.
Hash: 8f9f8c5803da9bb4274cabdd5f256aee25acd2357ed851543968dcd1c2a2fa24
Salt: 305c2fbeb04951d82a7e91a26642b589

(root@kali)-[/home/kali]
# cat hash_and_salt.py

import hashlib
import os

def hash_password(password, salt=None):
    if salt is None:
        salt = os.urandom(16) # Generate a random 16-byte salt
        print(f"Generated Salt (in hex): {salt.hex()}")

    salted_password = password.encode('utf-8') + salt
    hashed_password = hashlib.sha256(salted_password).hexdigest()
    print(f"Hashed Password: {hashed_password}")

    return hashed_password, salt

password = input("Enter the password to hash: ")
hashed_password, salt = hash_password(password)

print("\nSave this hashed password and salt securely.")
print(f"Hash: {hashed_password}")
print(f"Salt: {salt.hex()}")

(root@kali)-[/home/kali]
#
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2024.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

kali-linux-2024.2

Metasploitable2

Home

kali-linux-2024.2-vmware-a...

1 2 3 4

root@kali:/usr/share/wordlists

File Actions Edit View Help

```
(root@kali)-[/usr/share/wordlists]
# nano hash_and_salt.py

(root@kali)-[/usr/share/wordlists]
# python3 hash_and_salt.py

Hashed Password: 5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8

(root@kali)-[/usr/share/wordlists]
# echo "5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8" > hashes.txt

(root@kali)-[/usr/share/wordlists]
# cat hashes.txt

5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8

(root@kali)-[/usr/share/wordlists]
# cd /usr/share/wordlists/

(root@kali)-[/usr/share/wordlists]
# ls
amass crack.txt dirb dirbuster dnsmap.txt fasttrack.txt fern-wifi hash_and_salt.py hashes.txt hydra.restore john.1
```

kali-linux-2024.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

kali-linux-2024.2

Metasploitable2

root@kali: /usr/share/wordlists

```
(root@kali)-[/usr/share/wordlists]
# nano rockyou.txt

(root@kali)-[/usr/share/wordlists]
# ls
amass      dirb      dnsmap.txt  fern-wifi  hashes.txt  john.lst  metasploit  rockyou.txt  sqlmap.txt  wifite.
crack.txt  dirbuster fasttrack.txt hash_and_salt.py hydra.restore legion     nmap.lst    seclists    wfuzz

(root@kali)-[/usr/share/wordlists]
# gunzip rockyou.txt

gzip: rockyou.txt: unknown suffix -- ignored

(root@kali)-[/usr/share/wordlists]
# gunzip -- rockyou.txt

gzip: rockyou.txt: unknown suffix -- ignored

(root@kali)-[/usr/share/wordlists]
# cat rockyou.txt

123
password
Password
Password123
password123
hello
how

(root@kali)-[/usr/share/wordlists]
# head rockyou.txt

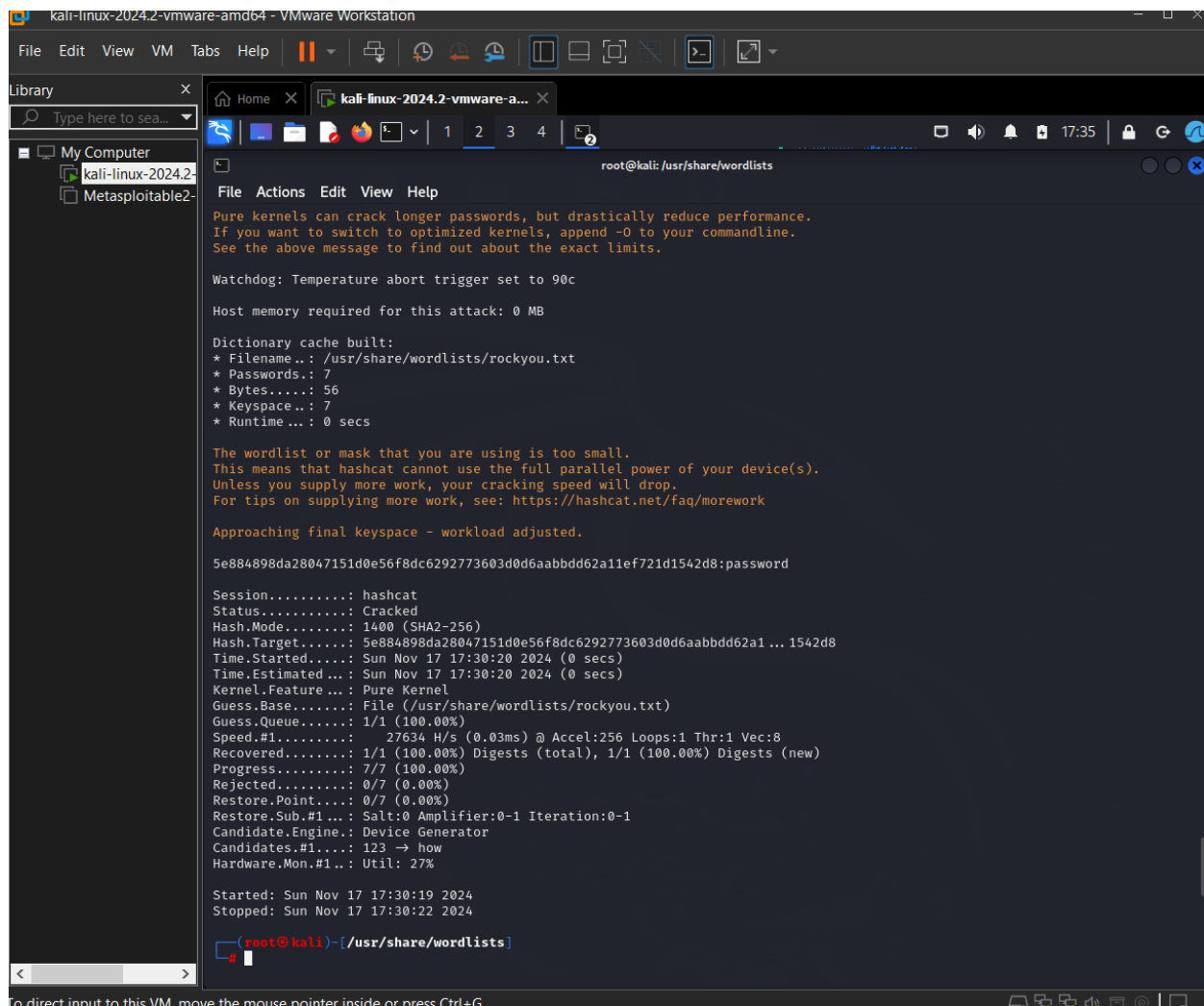
123
password
Password
Password123
password123
hello
how

(root@kali)-[/usr/share/wordlists]
# wc -l rockyou.txt

7 rockyou.txt

(root@kali)-[/usr/share/wordlists]
# gunzip rockyou.txt.gz
```

to direct input to this VM, move the mouse pointer inside or press Ctrl+G.



```
File Actions Edit View Help
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache built:
* Filename.: /usr/share/wordlists/rockyou.txt
* Passwords.: 7
* Bytes.....: 56
* Keyspace..: 7
* Runtime...: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.

5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a1ef721d1542d8:password

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1400 (SHA2-256)
Hash.Target.....: 5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a1 ... 1542d8
Time.Started.....: Sun Nov 17 17:30:20 2024 (0 secs)
Time.Estimated...: Sun Nov 17 17:30:20 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 27634 H/s (0.03ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 7/7 (100.00%)
Rejected.....: 0/7 (0.00%)
Restore.Point....: 0/7 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: 123 -> how
Hardware.Mon.#1..: Util: 27%

Started: Sun Nov 17 17:30:19 2024
Stopped: Sun Nov 17 17:30:22 2024

(root@kali)-[/usr/share/wordlists]
#
```

```
(root@kali)-[/usr/share/wordlists]
# cat hash_and_salt.py

import hashlib

password = "password" # Simple password for demonstration
hashed_password = hashlib.sha256(password.encode('utf-8')).hexdigest()
print(f"Hashed Password: {hashed_password}")
```

Q:Why Hashing and Salting Are Essential in Cybersecurity?

1. **Hashing:** Converts passwords into a fixed-length, unreadable string (a "hash") using mathematical algorithms. This ensures that even if someone accesses the stored hashes, they cannot see the original passwords.

2. **Salting:** Adds a unique random value (a "salt") to each password before hashing. This makes each hash unique, even if two users have the same password.

Importance:

- **Protection Against Attacks:** Hashing makes it hard to recover the original password. Salting prevents attackers from using precomputed hash databases (like rainbow tables).
- **Strengthens Security:** Even if an attacker gets the password database, salting and hashing together make it extremely difficult to crack passwords.

In short, hashing and salting ensure stored passwords are secure and not easily exploitable.

Task 5: Basic Threat Identification

Environment

1. Target System: Metasploitable 2
IP Address: 150.1.7.104
2. Scanner: Qualys or similar tool

Screenshots of scanning report



Scan Results

Title:	metasploit - 20240816
Asset Groups:	All
IPs:	150.1.7.104
Excluded IPs:	-
Options Profile:	Initial Options

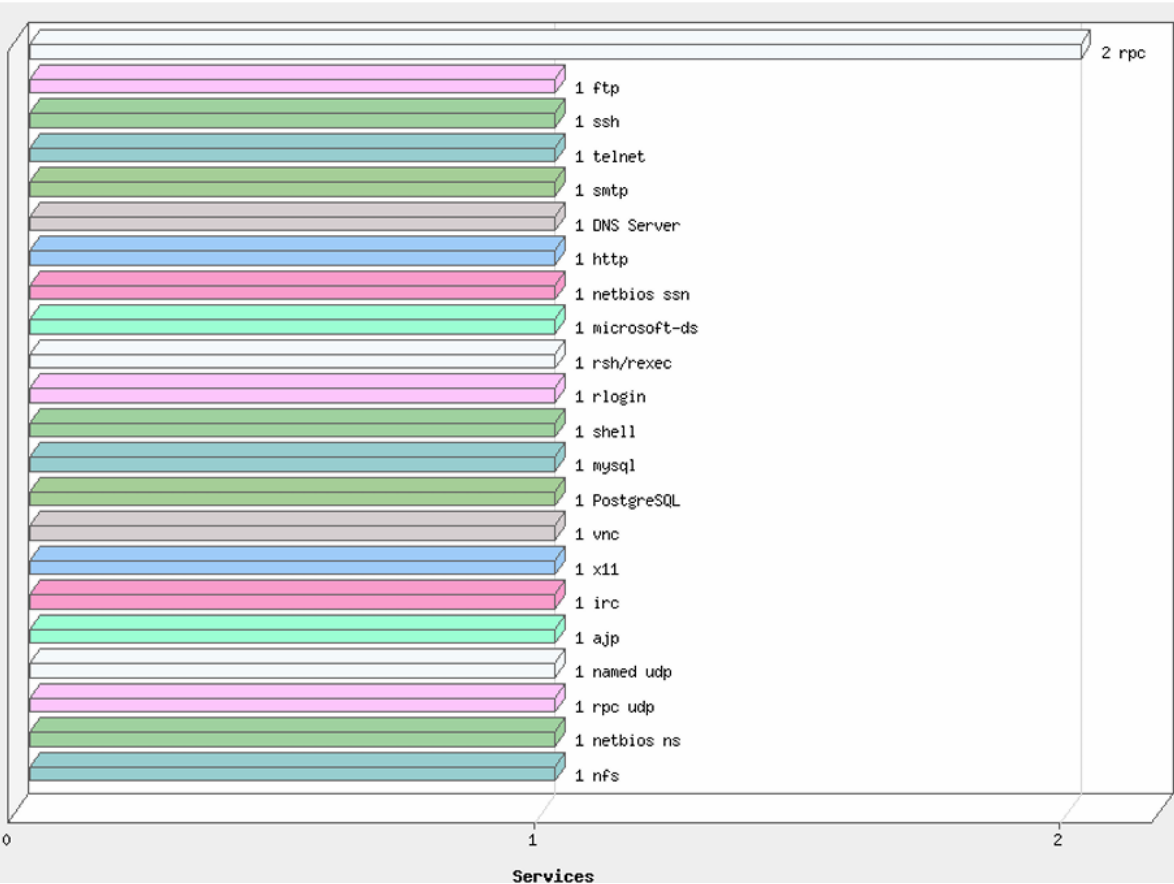
Summary of Vulnerabilities

Vulnerabilities Total	330	Security Risk (Avg)	5.0
-----------------------	-----	---------------------	--

by Severity				
Severity	Confirmed	Potential	Information Gathered	Total
5	2	13	0	15
4	10	44	0	54
3	32	106	5	143
2	21	31	13	65
1	2	0	51	53
Total	67	194	69	330

5 Biggest Categories				
Category	Confirmed	Potential	Information Gathered	Total
General remote services	35	35	20	90
DNS and BIND	3	56	1	60
CGI	5	49	2	56
Web server	4	18	5	27
Information gathering	3	1	21	25
Total	50	159	49	258

Services Detected



Detailed Results

150.1.7.104 (metasploitable.localdomain, METASPLOITABLE) Lir

Vulnerabilities (67)

 5 EOL/Obsolete Software: ISC BIND 9.1.x - 9.5.x Detected

QID:	105508
Category:	Security Policy
Associated CVEs:	-
Vendor Reference:	BIND Software Status
Bugtraq ID:	-
Service Modified:	09/07/2023
User Modified:	-
Edited:	No
PCI Vuln:	Yes

THREAT:

Scan Results

4 Apache Tomcat AJP File Inclusion Vulnerability (unauthenticated check)

port 8009/tcp

QID: 87413
Category: Web server
Associated CVEs: [CVE-2020-1938](#)
Vendor Reference: [Tomcat](#)
Bugtraq ID: -
Service Modified: 08/08/2024
User Modified: -
Edited: No
PCI Vuln: Yes

Scan Results

page 16

THREAT:

Apache Tomcat is an open source web server and servlet container developed by the Apache Software Foundation.

Apache Tomcat fixed a vulnerability (CVE-2020-1938) that allows an attacker to read any webapps files. If the Tomcat instance supports file uploads, the vulnerability could also be leveraged to achieve remote code execution.

Affected Versions:

Apache Tomcat 9.0.0 through 9.0.30

Apache Tomcat 8.5.0 through 8.5.50

Apache Tomcat 7.0.0 through 7.0.99

IMPACT:

Successful exploitation allows an attacker to read or include any file in all webapp directories on Tomcat, such as webapp configuration files, source code, etc. Remote code execution is also possible.

SOLUTION:

Updated versions of Apache Tomcat are available that fix these vulnerabilities.

Workaround: Temporarily disable the AJP protocol port.

EXPLOITABILITY:

 exploitdb

Reference: CVE-2015-5477
Description: ISC BIND 9 - TKEY Remote Denial of Service (PoC)
Link: <https://www.exploit-db.com/exploits/37723>

Reference: CVE-2015-5477
Description: ISC BIND 9 - TKEY (PoC)
Link: <https://www.exploit-db.com/exploits/37721>

 seebug

Reference: CVE-2015-5477
Description: BIND9 TKEY assert Dos
Link: <https://www.seebug.org/vuldb/ssvid-89243>

 packetstorm

Reference: CVE-2015-5477
Description: BIND TKEY Query Denial Of Service
Link: <https://packetstormsecurity.com/files/132926/BIND-TKEY-Query-Denial-Of-Service.html>

 metasploit

Reference: CVE-2015-5477
Description: BIND TKEY Query Denial of Service
Link: https://raw.githubusercontent.com/rapid7/metasploit-framework/master/modules/auxiliary/dos/dns/bind_tkey.rb

 0day.today

Reference: CVE-2015-5477
Description: ISC BIND9 TKEY Remote DoS PoC
Link: <https://0day.today/exploit/23970>

Reference: CVE-2015-5477
Description: BIND9 TKEY Query Denial of Service Exploit
Link: <https://0day.today/exploit/23960>

Reference: CVE-2015-5477
Description: BIND9 - TKEY PoC Exploit
Link: <https://0day.today/exploit/23948>

 github-exploits

Reference: CVE-2015-5477
Description: knqyf263/cve-2015-5477 exploit repository
Link: <https://github.com/knqyf263/cve-2015-5477>

4 ISC BIND Denial of Service (DoS) Vulnerability (CVE-2015-5477)

port 53/tcp

QID: 15161
Category: DNS and BIND
Associated CVEs: [CVE-2015-5477](#)
Vendor Reference: [aa-01272](#)
Bugtraq ID: -
Service Modified: 08/15/2024
User Modified: -
Edited: No
PCI Vuln: Yes

THREAT:

Scan Results

page 9

ISC BIND (Berkley Internet Domain Name) is an implementation of DNS protocols.

BIND Affected versions:

All versions of BIND 9 from BIND 9.1.0 (inclusive) through BIND 9.9.7-P1 and BIND 9.10.2-P2 are vulnerable.

IMPACT:

An error in the handling of TKEY queries can be exploited by an attacker for use as a denial-of-service vector, as a constructed packet can use the defect to trigger a REQUIRE assertion failure, causing BIND to exit.

SOLUTION:

Customers are advised to upgrade latest release of ISC BIND. (<https://kb.isc.org/docs/aa-01272>)

Patch:

Following are links for downloading patches to fix the vulnerabilities:

aa-01272 (<https://kb.isc.org/docs/aa-01272>)

2. Open "Local Policies-->Security Options".
3. Make sure "Additional restrictions of anonymous connections" is set to "No access without explicit anonymous permissions".
4. Restart your computer.

Windows XP/2003: 1. Start "Control Panel-->Administrative Tools-->Local Security Policy".

2. Open "Local Policies-->Security Options".
3. Make sure the following two policies are enabled:
 - * Network Access: Do not allow anonymous enumeration of SAM accounts
 - * Network Access: Do not allow anonymous enumeration of SAM accounts and shares
4. Disable Network Access: Let Everyone permissions apply to anonymous users.
5. Restart your computer. The above settings have no impact on domain controllers. If this vulnerability was discovered on a domain controller, recommended settings may not have any effect. Samba:
 - Make the following settings in smb.conf:
 - * set "security" to "user" or "domain" or "server" as per your requirements.
 - * set "map_to_guest" to "Never"

SECURITY = USER

This is the default security setting in Samba 2.2. With user-level security a client must first "log=on" with a valid username and password (which can be mapped using the username map parameter). Encrypted passwords can also be used in this security mode. Parameters such as user and guest only if set are then applied and may change the UNIX user to use on this connection, but only after the user has been successfully authenticated.

SECURITY = SERVER

In this mode Samba will try to validate the username/password by passing it to another SMB server, such as an NT box. If this fails it will revert to security = user, but note that if encrypted passwords have been negotiated then Samba cannot revert back to checking the UNIX password file, it must have a valid smbpasswd file to check users against. See the documentation file in the docs/ directory ENCRYPTION.txt for details on how to set this up.

SECURITY = DOMAIN

This mode will only work correctly if smbpasswd has been used to add this machine into a Windows NT Domain. It expects the encrypted passwords parameter to be set to true. In this mode Samba will try to validate the username/password by passing it to a Windows NT Primary or Backup Domain Controller, in exactly the same way that a Windows NT Server would do.

Also add "restrict anonymous = 2" to the "[global]" configuration section.

Note: Setting this parameter in Samba versions prior to 4 may impact Samba's ability to service Windows 9x clients, act as a Domain Controller or serve as the Master Browser.

Windows Server 2008, 2012, 2016 Disable Server 2008 Null Sessions

(<http://social.technet.microsoft.com/Forums/en-US/winservergen/thread/841523db-8c4b-43a0-9f28-be7270f92e2b>), Disable Server Null Sessions (<https://social.technet.microsoft.com/Forums/ie/en-US/522a652b-750c-4ccf-b182-362e45cbe9a7/domain-controller-smb-null-session-enumeration?forum=winserverDS>), Pre-Windows 2000 Compatible Access (<https://docs.microsoft.com/en-us/answers/questions/83025/qid70003-is-reported-for-2012-r2-domain-controller.html>)

4 Null Session/Password NetBIOS Access

QID: 70003
Category: SMB / NETBIOS
Associated CVEs: [CVE-1999-0519](#)
Vendor Reference: -
Bugtraq ID: -
Service Modified: 04/07/2022
User Modified: -
Edited: No
PCI Vuln: Yes

THREAT:

Unauthorized users can connect to this NetBIOS service without a password.

IMPACT:

Unauthorized users may be able to exploit this vulnerability to obtain sensitive information about your system resources, such as a list of all accounts or shared resources on this host. For Windows hosts, unauthorized users may also be able to access the registry, and depending on the Windows version and registry permission settings, make modifications to the registry.

SOLUTION:

Null NetBIOS sessions can be disabled using the following methods:

Windows NT: 1. Set the following registry key:
HKLM\System\CurrentControlSet\Control\Lsa
Name: RestrictAnonymous
Type: REG_DWORD Value: 1
2. Restart your computer.

Windows 2000:

1. Start "Control Panel-->Administrative Tools-->Local Security Policy".

2. Open "Local Policies-->Security Options".

4 RPC Mountd Allows Remote Anonymous File System Root Mount

QID: 68520
Category: RPC
Associated CVEs: -
Vendor Reference: -
Bugtraq ID: -
Service Modified: 07/20/2023
User Modified: -
Edited: No
PCI Vuln: Yes

THREAT:

The host allows the file system root "/" to be remotely and anonymously mounted.

Detection is enhanced by scanner module to post

QID as practice when module failed to find the list of directory, but upgrade as confirmed when we are able to find the list of dirs in / mount.

There are also improvements made in the reporting of version and port information for each finding.

IMPACT:

Successful exploitation of this vulnerability can lead to heavy information disclosure, which consequently can easily lead to system compromise.

SOLUTION:

Configure the host's "mount" daemon to disallow root and other mount points with sensitive content that should not be publically accessible. Typically, the configuration file for the "rpc.mountd" daemon is "/etc/exports".

Based on the scan results document, here are five common threats and how they might be exploited:

1. Remote Shell Vulnerability (Port 1524)

Threat: An unauthenticated remote shell was detected, likely installed by a previous attack. This provides attackers with full control over the system.

Exploit Example: An attacker could execute arbitrary commands as root, compromising the entire server.

2. Remote Execution Service (rexec, Port 512)

Threat: The rexec service allows remote command execution based on login/password authentication.

Exploit Example: Attackers could brute-force user credentials and execute commands remotely, potentially as root.

3. Null Session/NetBIOS Access (SMB/NetBIOS)

Threat: Unauthorized users can establish null sessions, allowing them to enumerate user lists and shared resources.

Exploit Example: Attackers use null sessions to gather user data and launch brute-force attacks on weak passwords.

4. TWiki Remote Command Execution

Threat: A flaw in the TWiki web application allows attackers to inject commands via unsanitized user input.

Exploit Example: An attacker crafts a URL to execute system commands, leading to unauthorized access or data theft.

5. Apache Tomcat AJP File Inclusion (Ghostcat, Port 8009)

Threat: An attacker can read sensitive files or execute code via the Tomcat AJP protocol.

Exploit Example: Exploiting this flaw to read configuration files and escalate privileges to take over the web server.